Informe de auditoría técnica y de seguridad — Cantera

Fecha: 16 de octubre de 2026, America/Guatemala. Alcance: copia de trabajo `ProyectoFinalA`, aplicación Symfony 7.4, configuración de producción local, MySQL 8.4.9 y pruebas automatizadas y de navegador.

Dictamen

La aplicación cuenta con autenticación, autorización, CSRF, hashes de contraseñas, consultas parametrizadas y validación de archivos. Se corrigieron debilidades adicionales en dependencias, configuración de producción, autenticación, cabeceras HTTP, fechas y separación de tokens. El sistema resulta utilizable para una demostración controlada, con las limitaciones descritas a continuación.

No se certifica que esté libre de vulnerabilidades ni listo para un servicio público permanente. La contraseña débil solicitada para `admin`, la antigüedad del PHP local, los datos públicos de jugadores y la dependencia de una computadora personal requieren atención antes de un despliegue definitivo.

Método y cobertura

Se revisaron las seis entidades, los seis controladores, formularios, servicios, comandos de consola, repositorios, migraciones MySQL, configuración Symfony, plantillas Twig, JavaScript propio, arranque local, documentos y empaquetado. Se consultó el aviso oficial del componente vulnerable y se ejecutó Composer Audit.

Las pruebas funcionales usan SQLite en memoria. Las tres pruebas de integración usan `cantera_torneo_test`, verifican ese nombre antes de trabajar y revierten sus transacciones. No se borraron ni recrearon tablas de la base principal. En producción se hicieron lecturas, inicios/cierres de sesión y el cambio de contraseña solicitado. Las pruebas de navegador no inscriben ni eliminan jugadores.

Esta revisión no incluyó pentesting de la infraestructura de Cloudflare, análisis forense de Windows, pruebas de carga masiva, recuperación completa desde un respaldo ni comprobación de un alojamiento remoto. Las capturas antiguas del manual son ilustrativas; no constituyen evidencia de cada comprobación actual.

Hallazgos corregidos

ID	Prioridad	Hallazgo y corrección	Evidencia
A01	Alta, dependencia	`symfony/expression-language` 7.4.18 tenía el aviso CVE-2026-109449 de agotamiento por expresiones profundamente anidadas. Actualizado a 7.4.21; `symfony/cache` pasó a 7.4.21 por dependencia. No se encontró una entrada de usuario que evalúe expresiones en este proyecto.	Composer Audit final sin avisos ni paquetes abandonados.
A02	Alta, configuración	El secreto efectivo de producción estaba vacío. Se generó un secreto criptográfico de 32 bytes aleatorios, almacenado solo en `.env.local`. Se amplió la plantilla de instalación.	La lectura del parámetro antes del cambio producía `EmptyParameterValueException`; el acceso real funciona después del cambio.
A03	Alta, autenticación	No había limitación de intentos de login. Se instaló `symfony/rate-limiter` y configuraron 5 intentos/minuto por usuario e IP, además del límite global por IP del framework.	Tras varios intentos incorrectos, incluso la clave válida queda temporalmente bloqueada en la prueba aislada.
A04	Media	Symfony no reconocía explícitamente el HTTPS reenviado por el túnel local. Se confía solo en `X-Forwarded-Proto` de `127.0.0.1` y `::1`; cookies HttpOnly, SameSite=Lax y Secure automático.	Pruebas de proxy autorizado/no autorizado y comprobación de cookie en navegador.
A05	Media	Faltaban cabeceras de defensa. Se añadieron nosniff, DENY contra marcos, política de referente, restricción de permisos y CSP para base, objetos, marcos y destinos de formularios. Las respuestas de Symfony son privadas y no-store.	Pruebas HTTP automatizadas y navegador.
A06	Media	Jornadas e incidencias podían normalizar fechas inexistentes. Una extensión compartida valida fechas ISO y calendario con `checkdate()` antes de transformarlas. También se usa en jugadores.	Se rechaza 30 de febrero en altas y edición de jornada, incidencia y suspensión.

A07	Media	Equipos y jugadores con el mismo ID usaban la misma identidad de token de eliminación. Se separaron como `delete_equipo_ID` y `delete_jugador_ID`.	Reutilizar el token de equipo para borrar un jugador devuelve 403 y conserva el registro.
A08	Media	No había una bitácora específica de solicitudes de escritura. Se agregó un canal rotativo de auditoría con 30 archivos diarios como máximo.	`AuditSubscriber` registra ruta, método, estado HTTP e IDs, sin cuerpo, contraseña ni token.
A09	Media	La documentación indicaba una copia de la contraseña en texto plano. Se sustituyó el contenido privado por una nota y se corrigió la documentación.	MySQL conserva un hash verificado; el archivo auxiliar ya no contiene la clave.
A10	Funcional	Faltaba una revisión repetible de registros antiguos frente a las validaciones actuales. Se añadió `app:auditar-datos`, de solo lectura.	39 registros revisados; 1 jugador con incumplimientos.

Las restricciones de nombres y edad mínima de 6 años se habían añadido en la revisión anterior. Esta auditoría volvió a probarlas junto con las modificaciones nuevas. No se cambió el mínimo general de 12 caracteres de `app:crear-admin`. La contraseña solicitada para la cuenta existente fue una excepción puntual.

Controles que ya estaban presentes y se conservaron

- **Autenticación:** formulario de login, hash de contraseña y sesión Symfony.

- **Autorización:** `ROLE_ADMIN` en rutas de escritura y atributos `IsGranted`. Los visitantes consultan; no pueden crear, editar ni eliminar.

- **CSRF:** login, logout, formularios de escritura y eliminaciones. Los filtros GET de reportes no modifican datos y no requieren token.

- **SQL:** parámetros de Doctrine para filtros; tablas de importación tomadas de una lista fija. Índice único para jugador/jornada y claves foráneas en MySQL.

- **XSS:** escape automático de Twig. El uso de `raw` hallado se limita a trazos SVG de un catálogo interno; no recibe texto libre del usuario.

- **Fotografías:** JPEG/PNG/WebP, hasta 2 MB, 4096 × 4096, comprobación del contenido, nombres aleatorios, directorio fuera de `public/` y patrón estricto de lectura.

- **Integridad:** se impide borrar equipos con jugadores y jugadores/jornadas con registros dependientes. Las migraciones no borran el historial por cascada.

- **Secretos:** `.env.local`, configuración privada, datos MySQL y respaldos no están versionados ni se incluyen en el ZIP generado con lista de archivos permitidos.

Protocolos y mecanismos: diferencias importantes

Elemento	Qué protege	Límite
HTTPS del enlace Cloudflare	Cifra la conexión navegador–Cloudflare.	La auditoría actual probó la aplicación local y la cabecera del proxy; no certifica TLS de un hosting remoto.
Túnel Cloudflare	Conecta el servicio local con la red de Cloudflare.	Requiere computadora, Internet y proceso activos. El enlace temporal cambia.
HTTP de loopback	PHP escucha en 127.0.0.1:8000 para uso local.	No es un servidor de producción ni una conexión TLS directa.
MySQL en 127.0.0.1:3307	Mantiene el acceso de esta instancia en la computadora.	No se comprobó cifrado de una conexión MySQL remota.
CSRF, roles, hashes y cookies	Protegen solicitudes, permisos y credenciales.	Son mecanismos de seguridad de aplicación, no protocolos de red.

Riesgos y pendientes

1. **Alto: contraseña débil de admin, aceptada expresamente por el usuario.** Es corta y predecible. El hash y el límite de intentos no la convierten en una contraseña fuerte. Cambiarla antes de mantener el sitio expuesto a Internet. El informe y el ZIP no incluyen su valor.

2. **Alto antes de producción: PHP local 8.2.12.** Es una revisión antigua del entorno XAMPP. Composer comprueba compatibilidad y avisos de paquetes, no la seguridad completa del ejecutable PHP ni de Windows. Actualizar el runtime mediante una instalación compatible y repetir las pruebas. No se sustituyó XAMPP durante esta auditoría para evitar afectar otros proyectos.

3. **Confidencialidad:** consultas, fechas de nacimiento y fotos de jugadores son públicas por el diseño acordado. Revisar qué datos deben mostrarse antes de usar registros reales. No se cambió unilateralmente ese modelo de acceso.

4. **Dato inválido existente:** `Jugador #14` incumple nombres, apellidos y edad. Corregirlo desde Editar con datos verdaderos o eliminarlo si es un registro de prueba. No se inventaron datos ni se eliminó información del usuario.

5. **Privilegios MySQL:** `cantera` tiene ALL PRIVILEGES únicamente sobre `cantera_torneo`, sin privilegios globales de administración. Conviene separar la cuenta de migraciones de una cuenta de ejecución con solo CRUD. No se revocaron permisos silenciosamente porque el flujo actual ejecuta migraciones con esa misma cuenta.

6. **Escalabilidad y concurrencia:** listados y reportes cargan conjuntos completos; no hay paginación general ni pruebas masivas de carga. Una carrera excepcional entre comprobación y escritura puede terminar en error de base de datos; los índices y claves foráneas siguen protegiendo la integridad. Considerar manejo de conflictos y paginación para más usuarios o datos.

7. **Bitácora limitada:** registra solicitudes y estados HTTP, no diferencias campo por campo ni un sello inalterable. Una redirección no demuestra por sí sola que hubo un cambio. Administradores del sistema pueden modificar logs.

8. **Proxy y límites:** todos los accesos del túnel aparecen desde loopback para el limitador. Esto restringe ataques, pero puede bloquear temporalmente a varios usuarios juntos. No se confía indiscriminadamente en IP reenviadas por el cliente.

9. **CSP parcial:** la política no restringe todavía fuentes de scripts; hacerlo requiere integrar nonces/hashes con importmap y Turbo. El control principal frente a texto malicioso sigue siendo el escape de Twig.

10. **Operación:** no hay monitorización externa, copias automáticas comprobadas, prueba completa de restauración ni alojamiento permanente. Las fotos antiguas se conservan y pueden ocupar espacio. No se eliminaron durante la auditoría.

Resultados reproducibles

- `php bin/phpunit`: **26 pruebas y 475 comprobaciones correctas**, incluyendo integración MySQL, acceso, CSRF, fechas, fotografías, reportes, escape HTML y filtros.

- `php bin/console doctrine:schema:validate --env=prod --no-debug`: mapeo y esquema correctos.

- `php bin/console lint:container --env=prod --no-debug`: contenedor correcto.

- `php bin/console lint:twig frontend/templates --env=prod --no-debug`: 20 plantillas válidas.

- `composer check-platform-reqs`: requisitos de paquetes satisfechos.

- `composer audit --locked`: sin avisos de seguridad conocidos ni paquetes abandonados en la consulta final del 16/10/2026. El resultado puede cambiar con nuevos avisos.

- `php bin/console app:auditar-datos --env=prod --no-debug`: 39 registros, 1 con incumplimientos. Devuelve código 1 cuando encuentra datos inválidos, de forma deliberada.

- Referencias de fotografías con nombre gestionado por el sistema: ninguna ausente.

- Navegador: páginas públicas, formularios administrativos, login con la clave solicitada, logout, validación HTML, tamaño móvil, cabeceras y rutas privadas. **27 comprobaciones correctas y ningún error JavaScript.** Evidencia local detallada: `var/log/auditoria-browser.json`.

Los avisos de deprecación de Doctrine y la recomendación de instalar `intl` no equivalen a errores de pruebas, pero deben atenderse al actualizar el entorno.

Fuentes técnicas consultadas

- Aviso CVE-2026-109449 y versiones corregidas.

- Symfony 7.4: seguridad y limitación del login.

- Symfony 7.4: proxies de confianza.

La conclusión se limita a la versión revisada y a las comprobaciones descritas; no es una garantía absoluta ni sustituye la revisión del despliegue definitivo.